

Access Controls Policy

Field	Value
Document ID	SEC-POL-002
Version	1.0
Effective	June 4, 2026
Owner	Eric Franco, CEO
Next Review	June 4, 2027
Status	Active

1. Purpose and Scope

This Access Controls Policy defines how Navii, Inc. ("Navii") manages who can access its systems, infrastructure, customer data, and internal tools — and under what conditions. It establishes the principles, procedures, and technical controls that govern access across the full lifecycle: provisioning, use, review, and revocation.

This policy applies to:

- All employees, contractors, and third-party vendors with any access to Navii systems
 - All production, staging, and development environments
 - All systems that store, process, or transmit customer financial data
 - All internal tooling, code repositories, CI/CD pipelines, and cloud infrastructure
-

2. Governing Principles

2.1 Least Privilege

Every person and system is granted the minimum access required to perform their function — nothing more. Access is narrowed to specific resources, actions, and time windows wherever technically feasible.

2.2 Need to Know

Access to customer financial data is granted only when there is a documented, legitimate business reason. Curiosity, convenience, or seniority alone do not justify access.

2.3 Separation of Duties

No single individual has unchecked control over critical operations. Where team size allows, write access to production systems and the ability to approve production changes are held by different parties.

2.4 Default Deny

All access defaults to denied. Permissions are explicitly granted; they are never assumed or inherited without deliberate approval.

2.5 Auditability

Every access grant, change, and revocation is logged. Every production access event is traceable to a named individual and a documented reason.

3. Access Tiers

Tier	Label	Scope	Requires
T1	Production — Customer Data	Direct access to RDS, live S3 buckets, customer records	CEO approval + MFA + documented reason
T2	Production — Infrastructure	AWS console, EC2, networking, Secrets Manager	CEO approval + MFA
T3	Production — Read-only Logs	CloudWatch, application logs (no raw financial data)	Role-based approval + MFA
T4	Staging / Dev	Non-production environments, dev databases with anonymized data	Standard onboarding
T5	Internal Tools	GitHub, Vercel, Linear, Slack	Standard onboarding + MFA

4. Identity and Authentication

4.1 Unique Accounts

Every person with system access has a uniquely named account tied to their identity. Shared accounts, shared passwords, and shared SSH keys are prohibited.

4.2 Multi-Factor Authentication (MFA)

MFA is **mandatory** for all accounts accessing T1–T3 systems and all T5 internal tools. Acceptable second factors:

Factor	Permitted	Notes
TOTP authenticator app (Google Authenticator, Authy, 1Password)	✔ Yes	Preferred
Hardware security key (FIDO2 / WebAuthn)	✔ Yes	Strongest option
Push notification (Duo, Okta Verify)	✔ Yes	Acceptable
SMS one-time code	✘ No	SIM-swap risk
Email one-time code	✘ No	Email compromise risk

MFA cannot be disabled for T1/T2 accounts under any circumstance, including during incident response.

4.3 Application-Level Authentication

The Naviio customer-facing application implements:

- Password-based authentication with bcrypt hashing (cost factor ≥ 12)
- TOTP-based MFA (opt-in, enforced for all internal/admin accounts)
- Session tokens issued as signed JWTs, expiring after 7 days or on explicit logout
- Session invalidation on password change or MFA status change
- Account lockout after 10 consecutive failed login attempts (15-minute lockout)
- Rate limiting on all `/api/auth/*` endpoints (20 requests/minute per IP)

4.4 SSH and Infrastructure Access

- SSH access to EC2 instances requires individual SSH key pairs. Password-based SSH is disabled system-wide.
 - SSH keys are rotated annually or immediately upon suspected compromise.
 - Access is restricted to a defined IP allowlist (engineer home/office IPs + corporate VPN).
 - All SSH sessions are logged and retained for 90 days.
-

5. Access Provisioning

5.1 New Employees and Contractors

Access is provisioned **after** the following are complete:

1. Signed employment or contractor agreement
2. Completed security awareness training
3. CEO approval for any T1–T3 access

Default access granted at onboarding:

- GitHub repository (read access to relevant repos)
- Vercel (preview deployments only)
- Staging environment
- Internal communication tools (Slack)

T1–T3 access is provisioned separately and only upon explicit request with documented justification.

5.2 Access Request Process

For any access beyond the default onboarding set:

1. **Requestor** submits a written request to the CEO specifying: system, permission level, business justification, and intended duration.
2. **CEO** approves or denies within 2 business days.
3. **Access is granted** with the narrowest permission scope that satisfies the stated need.
4. **Request and approval are logged** in the access control register.

5.3 Temporary Access

Temporary access (e.g., for incident response, vendor review, or a time-boxed project) is provisioned with an explicit expiry date. Automated expiry is used where technically available. Manual review and revocation occurs at the documented end date regardless.

6. Access to Customer Financial Data

Access to live customer financial data (Tier 1) is the most sensitive access class and requires the strictest controls.

6.1 Who May Access

- **CEO / Engineering Lead (Eric Franco):** Full access for incident response, infrastructure management, and debugging.
- **Engineers:** Read access to anonymized/aggregated data for debugging. Direct access to raw customer records requires individual CEO approval per incident.
- **No other role** has access to raw customer financial data.

6.2 Conditions for Production DB Access

Every production database access event must be:

- **Pre-approved** by the CEO (except in declared P0 incidents, where post-hoc documentation within 24 hours is required)
- **Scoped** to the minimum tables and records necessary
- **Logged** automatically by RDS audit logging and manually in the access log
- **Time-limited** — sessions are terminated when the documented task is complete

Direct production database queries are performed via the AWS RDS console or an authenticated CLI session through the VPC — never via an always-on database GUI tool with persistent connections.

6.3 Data Masking in Non-Production

Staging and development databases contain only anonymized or synthetically generated data. Real customer transaction records, account numbers, and OAuth tokens are never copied to non-production environments.

7. Third-Party and Vendor Access

7.1 Vendor Access Scope

Third-party vendors are granted the minimum access required to deliver their service:

Vendor	Access Granted	Access Denied
AWS	Hosts all infrastructure; Naviio controls all IAM policies	No access to application data without Naviio-initiated request
Vercel	Deployment access to application code	No access to production database or customer data
GitHub	Source code repository	No production infrastructure access
Anthropic	Receives aggregated financial summaries via API	No access to raw transactions, PII, or OAuth tokens

7.2 Vendor Access Requirements

- All vendor access is documented with a named account and a defined business purpose.
- Vendor credentials are rotated on contract renewal or upon vendor personnel changes.
- Vendor access is reviewed quarterly and revoked immediately upon contract termination.
- Vendors with access to any Naviio data must maintain SOC 2 Type II or equivalent.

7.3 Customer Integration Tokens

OAuth tokens and API keys that customers connect (Plaid, Stripe, QuickBooks, etc.) are:

- Stored encrypted at the application layer before database persistence
- Never logged in plaintext to application logs, error trackers, or monitoring tools
- Accessible only to the application service account; not accessible to individual engineers in plaintext
- Revoked immediately upon customer request or account deletion

8. Privileged Access Management

8.1 AWS IAM

- The root AWS account is used only for initial account setup and billing. It has MFA enabled and its credentials are stored in a secure password manager accessible only to the CEO.
- All operational access uses named IAM users or roles with narrowly scoped permissions.
- IAM policies follow least-privilege: no `*:*` policies, no wildcard resource ARNs except where technically required and documented.
- IAM access keys are rotated every 90 days. Unused access keys are deleted within 30 days of creation if never used.
- AWS CloudTrail is enabled in all regions and retains logs for 1 year.

8.2 Secrets and Credentials

- All production secrets (database credentials, API keys, signing secrets) are stored in AWS Secrets Manager.
- Secrets are never stored in environment files committed to version control, hardcoded in application code, or logged.
- GitHub secret scanning is enabled on all repositories. Any detected secret triggers immediate rotation and a security incident log entry.
- Engineers do not have direct access to production secret values. Secrets are injected into the runtime environment by the deployment pipeline.

8.3 SSH Key Management

Action	Trigger	SLA
Rotate SSH key	Annual schedule	Within 7 days of due date
Revoke SSH key	Employee departure	Within 2 hours
Revoke SSH key	Suspected compromise	Immediately
Add new SSH key	New hire / new device	CEO approval required

9. Access Reviews

9.1 Quarterly Reviews

Every 90 days, the CEO conducts a review of:

- All T1–T3 access grants — confirm ongoing need
- All active IAM users, roles, and policies
- All third-party vendor access

- All active SSH keys

Any access that cannot be justified is revoked within 5 business days of the review.

9.2 Event-Triggered Reviews

The following events trigger an immediate access review of the relevant accounts:

- Employee or contractor departure
- Role change (promotion, team transfer, project end)
- Suspected credential compromise
- Security incident involving any access tier
- Significant change to the product or infrastructure (new integration, new environment)

9.3 Annual Certification

Once per year, all access grants are re-certified from scratch — every individual re-requests access and every grant is re-approved. The annual re-certification replaces accumulated incremental grants with a clean, deliberate set.

10. Access Revocation

10.1 Timelines

Event	Revocation SLA
Voluntary departure (notice given)	By last day of employment
Involuntary termination	Within 2 hours of notification
Contractor engagement end	By contract end date, confirmed same day
Role change removing access need	Within 24 hours
Suspected compromise	Immediately

10.2 Revocation Checklist

Upon departure or role change, all of the following are revoked:

- ☐ AWS IAM user and access keys
 - ☐ GitHub organization membership
 - ☐ Vercel team membership
 - ☐ SSH public keys removed from all EC2 instances
 - ☐ Slack, Linear, and other internal tool access
 - ☐ Any shared credentials rotated if the individual had access
 - ☐ Active sessions invalidated (Naviio application and all internal tools)
 - ☐ Removal confirmed and logged in the access control register
-

11. Logging and Monitoring

All access events are logged and monitored:

System	What Is Logged	Retention
AWS CloudTrail	All AWS API calls, console logins, IAM changes	1 year
RDS Audit Logs	Database connections, queries on sensitive tables	90 days
Application Logs	Auth events (login, logout, MFA, failed attempts)	90 days
GitHub Audit Log	Repository access, clone, push, settings changes	90 days
Vercel Audit Log	Deployments, environment variable changes	90 days

Access logs are reviewed:

- **Automatically:** AWS GuardDuty analyzes CloudTrail in real time for anomalous patterns
- **On-alert:** Any GuardDuty finding triggers immediate manual review
- **Quarterly:** Logs are spot-checked as part of the quarterly access review

12. Policy Violations

Violations of this policy — including accessing systems beyond authorized scope, sharing credentials, bypassing MFA, or failing to report a suspected compromise — are subject to disciplinary action up to and including termination. Violations involving customer data may be reported to relevant regulatory authorities.

13. Exceptions

Exceptions to this policy (e.g., temporary MFA bypass for a specific tool during an incident) require:

1. Written approval from the CEO
2. A defined expiry date
3. An entry in the exceptions log

Exceptions are reviewed at expiry and either renewed with fresh justification or allowed to lapse.

14. Related Documents

- [Information Security Policy](#) — SEC-POL-001
- [Data Handling Procedures](#) — SEC-PROC-001
- [Incident Response Plan](#) — SEC-IRP-001